

Capitolo 4

Metamodello della documentazione e regole di authoring DDTA

Stato del capitolo - CLOSED / FINAL

Questo capitolo consolida il governed documentation metamodel DDTA fino a *Security Requirement* sulla baseline `ec6c0107e0d5c0460d2afcbe12dae6f40bc5e6c5`. Integra i risultati già chiusi di MR, Decision e FunctionalRequirement con S1 SpecializedRequirement, S1.5 Requirement abstraction e S2 SecurityRequirement. Non apre Base Analysis, BAE, Finding, STRIDE o il modello strutturale di provenance. Per lo scope corrente della tesi il capitolo è semanticamente chiuso e riapribile soltanto secondo le condizioni esplicite riportate in fondo.

4.1 Scopo del capitolo

La Documentation-Driven Threat Analysis (DDTA) assume che la documentazione governata di un progetto possa costituire una sorgente di conoscenza stabile, strutturata e tracciabile per analisi successive. Prima di definire un modello analitico è quindi necessario stabilire come la conoscenza progettuale debba essere scritta, organizzata e progressivamente specializzata.

Il problema affrontato in questo capitolo è anteriore al threat modeling vero e proprio. Non si chiede ancora quali minacce identificare o quale metodologia applicare. Si chiede quale struttura documentale consenta di governare:

- il problema generale affrontato dal progetto;
- le macro-responsabilità necessarie a trattarlo;
- le scelte che restringono lo spazio delle soluzioni;

- i comportamenti operativi che devono risultare da tali scelte;
- gli obblighi concern-specific che rafforzano i comportamenti senza sostituirli;
- identità e relazioni riusabili nelle fasi successive senza duplicazione semantica.

Il percorso principale è normalizzato come:

```
Project problem framing      [method precondition]
  -> Macro Requirement
  -> Decision
  -> Functional Requirement
  -> Specialized Requirement [abstract]
      -> Security Requirement
```

Per il perimetro della tesi, *Security Requirement* è la specializzazione concreta chiusa end-to-end. Il contratto generale di *Specialized Requirement* rimane metodologicamente neutro: tecniche differenti possono motivare specializzazioni relative a sicurezza, prestazioni o obblighi normativi/compliance senza richiedere MacroRequirement dedicati alla metodologia.

4.2 Separazione tra semantica, rappresentazione e tooling

DDTA separa quattro livelli per evitare che la serializzazione corrente o lo strumento diventino autorità semantica.

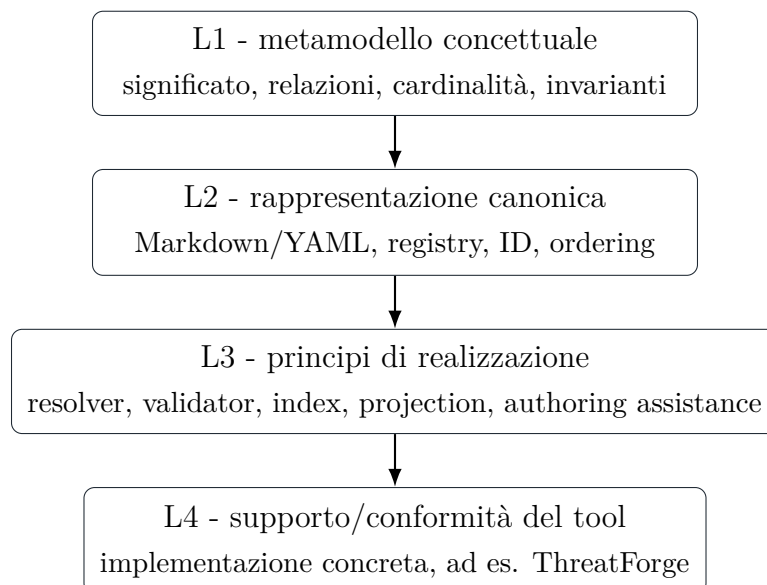


Figura 4.1: Separazione tra semantica, rappresentazione, realizzazione e tooling.

Una regola non appartiene al metamodello soltanto perché uno strumento può implementarla. Il test di sostituibilità rimane: se il tool venisse sostituito, la proprietà continuerebbe a descrivere il progetto governato? In caso affermativo è candidata a L1/L2; altrimenti appartiene più probabilmente a L3/L4.

4.3 Problem framing come preconditione metodologica

4.3.1 Perché il modello non parte direttamente dagli MR

Un *Macro Requirement* può diventare accidentalmente una descrizione della soluzione corrente. Formulare un progetto come “sistema di riconoscimento facciale con telecamera e modello ML” incorpora già scelte che potrebbero essere alternative a badge, impronta o provider esterno. Se tali scelte entrano nell'MR, la gerarchia non rende più visibile dove e perché lo spazio delle soluzioni è stato ristretto.

DDTA introduce quindi un passo di *problem framing* prima della decomposizione in documenti governati. Il framing non è un nuovo tipo di documento canonico nella baseline corrente.

Quale problema generale o classe di problemi deve affrontare il progetto, entro quale confine significativo, se rimuoviamo temporaneamente le scelte di soluzione correnti?

Il framing deve usare vocabolario del problema e del dominio. Provider, database, algoritmi, framework, device o metodologie di analisi vengono rimossi salvo che siano intrinseci al problema stesso.

4.3.2 Funzioni del framing

Il framing stabilisce un confine condiviso, consente di controllare coverage e overlap degli MR, crea un riferimento per riconoscere solution-vocabulary leakage e migliora la teachability. Non aggiunge un livello documentale: impedisce che il primo livello governato contenga già informazioni che dovrebbero emergere come scelte.

4.4 Gerarchia documentale progressiva

La closure finale distingue esplicitamente la gerarchia di tipo dalla catena di ownership dei documenti concreti.

4.4.1 Gerarchia di tipo

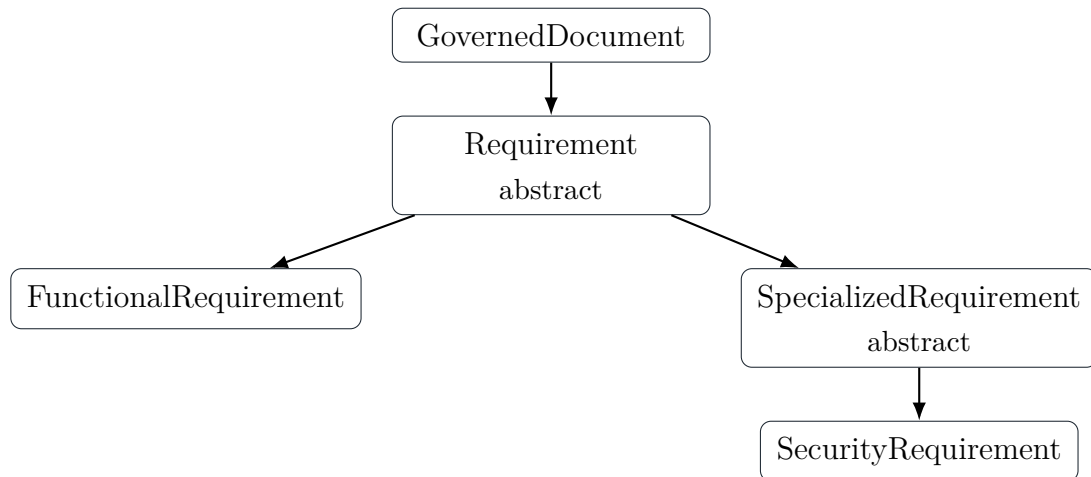


Figura 4.2: Gerarchia IS-A dei Requirement. MacroRequirement e Decision sono GovernedDocument, ma non Requirement.

4.4.2 Catena concreta di authoring e ownership

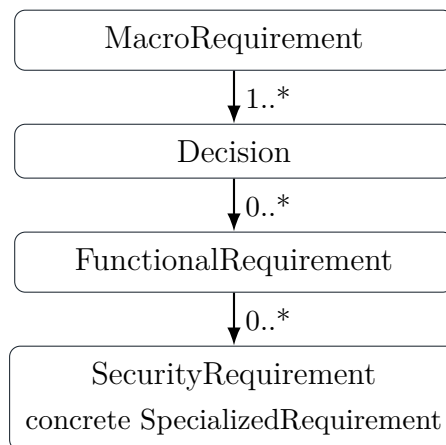


Figura 4.3: Percorso concreto nel caso security. Non esiste una istanza SpecializedRequirement intermedia tra FR e SecurityRequirement.

La gerarchia rappresenta contenimento semantico e specializzazione, non il parsing di un ID o di una cartella. Le relazioni parentali devono essere esplicite e validabili anche se cambia la rappresentazione L2.

4.5 Macro Requirement

4.5.1 Definizione

Un *Macro Requirement* è il documento radice che possiede una **responsabilità macro durevole e autonomamente significativa** necessaria a trattare il problema definito

dal framing. Spiega valore e risultato macro, contesto minimo, stakeholder e confine della responsabilità, senza selezionare una soluzione lower-level e senza specificare comportamenti atomici indipendentemente verificabili.

La domanda fondamentale è:

Nel problema di progetto già inquadrato, quale responsabilità macro stabile stiamo governando, quale risultato o valore di livello macro deve contribuire, perché conta e chi coinvolge?

Il termine “concern” può essere usato descrittivamente solo quando identifica una responsabilità macro autonomamente significativa. Non è sufficiente che una proprietà sia importante o trasversale per promuoverla a MR.

4.5.2 Forma semantica

Tabella 4.1: Forma semantica del Macro Requirement.

Concetto	Stato	Funzione
id	richiesto	identità stabile e tracciabilità
title	richiesto	nome conciso comprensibile nel dominio
lifecycle	richiesto	stato di governance corrente/storico
intent	richiesto	scopo, valore e risultato macro desiderato
context	richiesto	background minimo necessario all'interpretazione
stakeholders	richiesto	ruoli beneficiari, coinvolti, governanti o impattati
scope	richiesto semanticamente	confine della responsabilità macro
assumptions	opzionale	fatti trattati come veri per l'intero branch
constraints	opzionale	limiti applicabili all'intero branch
dependsOn	0..* MR	dipendenze macro non gerarchiche

Un campo separato **Objective** non è mantenuto nel core: nei corpus esaminati duplicava l'Intent oppure iniziava a decomporlo in comportamenti lower-level.

4.5.3 Invarianti dell'MR

Gli invarianti della baseline restano:

1. **Root hierarchy**: l'MR non ha parent gerarchico.
2. **Stable identity**: l'identità non dipende dalla forma testuale dell>ID.

3. **Problem anchoring:** l'MR deve essere interpretabile nel problem framing.
4. **Single macro responsibility:** un MR possiede una sola responsabilità macro coerente e autonomamente significativa.
5. **Child narrowing:** Decision e FR discendenti restringono la responsabilità, non introducono scope estraneo.
6. **No solution commitment leakage:** provider, architetture, algoritmi o meccanismi scelti appartengono a Decision salvo che siano intrinseci al dominio del problema.
7. **No FR-level obligation:** comportamenti atomici e operativi appartengono downstream.
8. **Broad domain readability:** il documento è leggibile da stakeholder competenti nel dominio senza richiedere conoscenza dell'implementazione corrente.
9. **Architecture resilience:** sostituire una soluzione lower-level non dovrebbe normalmente richiedere la riscrittura dell'MR.
10. **Temporal stability:** una nuova Decision non rende obsoleto l'MR se la responsabilità macro resta invariata.
11. **Explicit dependency:** relazioni complementari tra MR non devono essere nascoste come pseudo-gerarchia.
12. **Teachability:** title e Intent degli MR devono sostenere una mappa macro comprensibile del progetto.
13. **Analysis enabling, not analysis producing:** l'MR può fornire contesto utile, ma non crea automaticamente categorie o artefatti di una metodologia di analisi.
14. **Projection honesty:** una mappa didattica degli MR non deve essere presentata come DFD o threat model canonico.

Refinement emerso dal controesempio MR-0004

La formulazione "single macro concern" della baseline precedente viene resa più precisa come "single macro responsibility". Il cambiamento non vieta concern macro autentici; evita che security, privacy, performance, compliance o altri concern trasversali vengano usati come contenitori artificiali quando non possiedono una responsabilità macro autonoma.

4.5.4 Split, merge e dipendenze tra MR

La decomposizione non segue automaticamente l'architettura software. Due sottosistemi non richiedono necessariamente due MR e due responsabilità di dominio non devono

essere fuse soltanto perché oggi sono implementate dallo stesso componente. Quando due MR collaborano per uno scopo end-to-end, la collaborazione non implica co-ownership: una dipendenza macro può essere resa esplicita mediante `dependsOn`.

4.5.5 Isolated-MR review: heuristic graph-assisted

Il Macro Project Map può essere usato anche come strumento di quality review. Sia

$$G_{MR} = (V, E_{dependsOn})$$

il grafo dei MacroRequirement e delle relazioni canoniche `dependsOn`. Un nodo m tale che

$$\deg(m) = 0$$

non è automaticamente invalido. Il tool o il reviewer lo segnala però come **review point**.

La domanda principale è:

Se questo MacroRequirement restasse isolato nella Macro Project Map, rappresenterebbe comunque una responsabilità macro autonomamente significativa, oppure sta soprattutto raccogliendo proprietà o constraint che specializzano comportamenti posseduti da altri rami?

Domande di supporto:

1. Rimuovendo il nodo scompare una capability/responsabilità macro del progetto, oppure rimangono le capability e si perdono soprattutto proprietà specializzate?
2. Lo scope dell'MR parla prevalentemente di dati, decisioni o comportamenti posseduti da altri rami?
3. I suoi discendenti plausibili sarebbero soprattutto constraint di security, privacy, performance o compliance su FR altrui?
4. L'isolamento dipende invece da una relazione `dependsOn` mancante?
5. Il nodo è stato creato principalmente per dare una "casa" a una metodologia o categoria di analisi?

CANDIDATE - authoring heuristic, non invariante L1

Un MR isolato può essere: (a) una responsabilità macro autonoma valida; (b) un nodo con una dipendenza macro omessa; (c) un concern trasversale classificato troppo in alto. Il warning serve a forzare la domanda, non a imporre connettività artificiale.

4.5.6 Regression example: facial-access senza MR-0004

Il corpus facial-access storico conteneva quattro MR. MR-0001 dipendeva da MR-0002 e MR-0003; MR-0004 - Uso responsabile dei dati biometrici e delle decisioni automatiche era isolato.

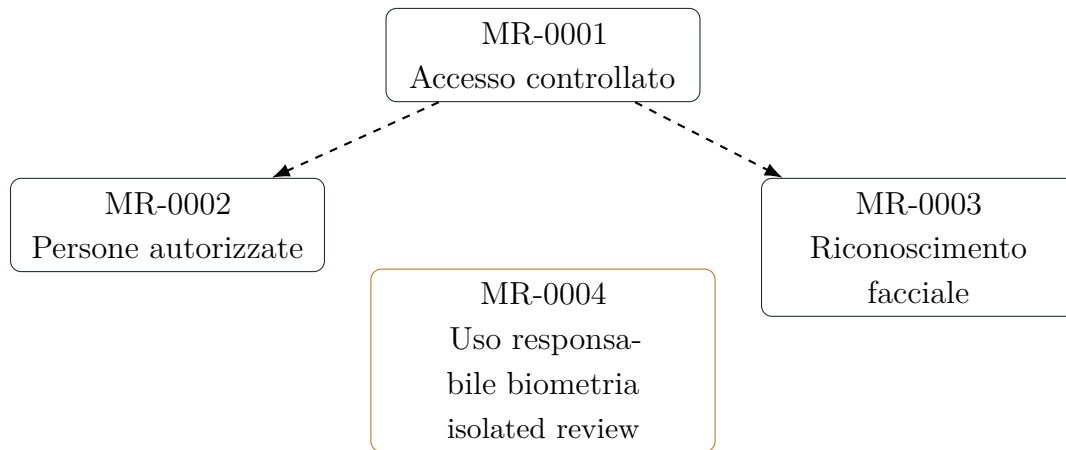


Figura 4.4: Il nodo isolato non è prova di errore; combinato con il contenuto trasversale di MR-0004 ha però motivato la regressione.

Applicando removal e classification test, le tre responsabilità macro restano complete senza MR-0004. I due commitment storici trovano collocazioni più naturali:

- la **limitazione di finalità dei dati biometrici** rafforza i FR che trattano biometria ed è candidata a SpecializedRequirement locale, eventualmente collegato in futuro a una fonte normativa condivisa;
- la **contestabilità/review degli esiti automatici** introduce una responsabilità operativa autonoma e può essere ricollocata sotto MR-0001 mediante una Decision sul principio di review e un FR che esegue il riesame.

CANDIDATE - corpus correction

Per il corpus di studio successivo a S1, MR-0004 viene ritirato come MacroRequirement autonomo. La correzione non cancella i suoi obblighi: li redistribuisce in base alla loro semantica. Questo è un esempio di feedback downstream che migliora la documentazione iniziale.

4.6 Decision

4.6.1 Dalla scelta al commitment significativo

Una *Decision* è un commitment significativo che restringe esattamente un *Macro Requirement*. Registra conoscenza non derivabile che cambia responsibility boundary, strategia,

policy, architettura o altro aspetto significativo e produce conseguenze downstream.

Quale commitment significativo restringe questo Macro Requirement, perché il progetto assume questa posizione e quali conseguenze accettiamo?

La forma minima rimane:

```
Decision
|- title
|- context
|- decision
'- consequences
```

Context è locale alla **Decision**; **Decision** contiene una posizione coerente; **Consequences** rende visibili effetti materiali e downstream obligations. Alternative e Rationale possono essere utili in L2 ma non sono campi L1 obbligatori separati.

4.6.2 Decision di responsibility boundary

Prima di scrivere FR occorre rendere esplicito chi possiede un comportamento. Una capability può essere implementata dal progetto oppure consumata da un sistema esterno. La scelta modifica il tipo di FR che il progetto deve possedere.

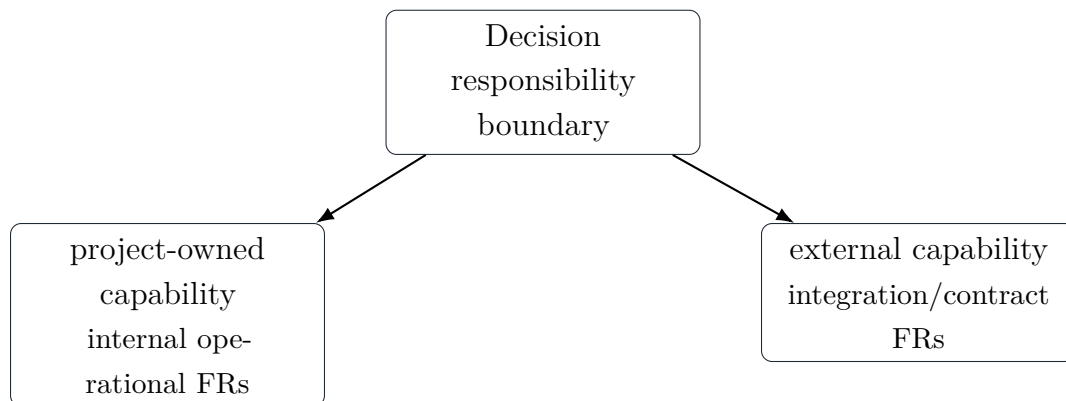


Figura 4.5: Una Decision sul responsibility boundary cambia il branch funzionale downstream.

4.6.3 Necessity/default Decision

La baseline privilegia una gerarchia costante MR -> Decision -> FR. Se non emerge un'alternativa materialmente distinta, una necessity/default Decision è ammessa soltanto dopo review: Context deve spiegare perché lo spazio ammissibile è singleton, il commitment non deve essere tautologico, le Consequences devono essere materiali e il documento deve essere riapribile se cambiano i vincoli.

4.6.4 Split e non ridondanza

Una Decision va divisa quando parti del commitment possono cambiare indipendentemente con conseguenze o trade-off autonomi. Non ogni frase tecnica è una Decision: tuning, nomi di classi o dettagli incidentali appartengono alla realizzazione se possono cambiare senza modificare il contratto governato.

4.7 Requirement - astrazione comune S1.5

S1.5 chiude l'astrazione comune fra `FunctionalRequirement` e `SpecializedRequirement`:

Un Requirement è una obbligazione normativa governata il cui contenuto normativo costituisce esattamente una unità di requisito coerente.

La forma L1 minima è:

```
Requirement [abstract]
  extends GovernedDocument
  normativeClause : NormativeClause [1..*]
```

Il Requirement è esso stesso l'obbligazione normativa governata. La precedente alternativa Requirement HAS-A NormativeObligation è rigettata: una metaclassa NormativeObligation separata non possiede nel baseline corrente identity, lifecycle, governance o responsabilità semantica indipendenti.

CLOSED - coherent unit

Tutte le normative clause possedute da un Requirement devono esprimere congiuntamente esattamente una obbligazione normativa coerente. Se una clausola può essere introdotta, revisionata, ritirata o valutata indipendentemente senza cambiare l'identità normativa delle altre, deve essere valutata come Requirement separato.

La rappresentazione L2 esatta delle normative clause resta separata dal contratto L1: prosa normativa e riferimenti strutturati possono supportarsi reciprocamente senza creare una seconda autorità semantica.

4.8 Functional Requirement

4.8.1 Definizione operativa

Un *Functional Requirement* è un obbligo operativo governato e indipendentemente valutabile che discende da esattamente una Decision. Esprime comportamento, servizio,

transizione o risultato osservabile che il progetto deve fornire nel contesto stabilito dal branch MR/Decision.

Data la Decision parent e una condizione/input applicabile, quale soggetto o capability deve compiere quale azione funzionale su/con quale oggetto o informazione, e quale risultato osservabile o failure behavior deve conseguire?

4.8.2 Gerarchia e ownership

La baseline chiude:

- ogni FR ha esattamente una Decision parent;
- l'MR owner è derivato dal parent della Decision;
- nessuna Decision è figlia di FR;
- un FR può possedere zero o più SpecializedRequirement;
- un nuovo commitment scoperto durante implementazione/review torna sotto l'MR appropriato come Decision, con revisione degli FR interessati.

4.8.3 Forma semantica e normative prose

A L1 il FunctionalRequirement specializza Requirement e aggiunge il parent Decision:

```
FunctionalRequirement
  extends Requirement
  parentDecision -> Decision 1
  specializedRequirement -> SpecializedRequirement 0..*
```

Le `normativeClause` [1..*] sono ereditate da Requirement e devono, nel caso FR, descrivere una sola obbligazione operativa indipendentemente assessabile: comportamento, servizio, transizione o risultato osservabile. Il precedente label `functionalObligation` viene normalizzato nella semantica comune di Requirement e non costituisce una seconda sorgente L1.

La prosa normativa rimane primaria. Una rappresentazione L2 può supportarla con riferimenti strutturati subject–predicate–object, ma tali riferimenti non sostituiscono condizioni, correlazione, atomicità o failure semantics e non modificano il coherent-unit invariant.

4.8.4 FunctionalPredicate e parametri

Il Predicate è governato da un metacontratto estendibile, non da un elenco universale congelato. Valori numerici e modalità operative devono essere classificati per semantica: strategia di acquisizione come Decision, target di latenza come Performance/Quality candidate, retention come Governance/Privacy candidate, limiti API come InterfaceContract candidate, tuning come realization/configuration.

4.8.5 Composizione tra MR senza doppia ownership

Un FR consumer può richiedere una capability posseduta da un altro MR senza acquisire un secondo parent. Il target canonico della relazione di consumption rimane deferred alla Base Analysis.

4.9 Specialized Requirement - semantica comune S1

S1 chiude il contratto generale prima della specializzazione SecurityRequirement.

Uno SpecializedRequirement è una specializzazione normativa governata di un singolo FunctionalRequirement che rafforza le condizioni sotto le quali il parent FR è considerato soddisfatto, imponendo un'obbligazione concern-specific che vale insieme all'obbligazione funzionale e non al suo posto.

La forma L1 aggiornata dopo S1.5 è:

```
SpecializedRequirement [abstract]
  extends Requirement
  parentFunctionalRequirement -> FunctionalRequirement 1
```

Per F parent e $S_1, \dots, S_n$ applicabili:

$$\text{Effective}(F) = F \wedge S_1 \wedge \dots \wedge S_n.$$

Le regole principali sono:

- ogni SR ha esattamente un FR parent; un FR può avere 0..* SR;
- rimuovere lo SR deve lasciare riconoscibile la funzione del parent FR;
- condizioni necessarie alla normale correttezza funzionale restano nell'FR;
- lo SR può richiedere un'azione positiva subordinata, ma una capability operativa autonoma tende a un FR separato;

- lo SR non prescrive il meccanismo o layer di realizzazione;
- lo stesso concern può specializzare più FR mediante SR locali distinti; il riuso della fonte normativa è un problema separato;
- obligation indipendentemente evolvibili o assessable restano Requirement separati anche se condividono il parent FR.

Ruolo metodologicamente neutro

SpecializedRequirement è il junction tra documentazione governata e obblighi concern-specific. Una metodologia di analisi non necessita di un proprio MR e non diventa autorità semantica dello SR.

4.10 Security Requirement - specializzazione concreta S2

CLOSED - definizione S2

Un SecurityRequirement è uno SpecializedRequirement la cui obbligazione normativa preserva una singola proprietà di sicurezza governata rilevante per il parent FunctionalRequirement e rende identificabile, nelle proprie normative clause, il security failure mode che costituirebbe la perdita o violazione di tale proprietà nel contesto del parent FR.

Il delta L1 minimo è:

```
SecurityRequirement
  extends SpecializedRequirement
  protectedSecurityProperty : SecurityProperty [1]
```

Il failure mode è obbligatorio semanticamente ma non viene duplicato in S2 come campo L1 separato: deve essere identificabile nella normative semantics del Requirement. La tassonomia esatta di **SecurityProperty** resta aperta; la cardinalità singola è invece chiusa dal coherent-unit/split test.

Gli invarianti S2 principali sono:

1. **Failure-mode explicitness:** le normative clause rendono identificabile lo stato/comportamento che violerebbe la proprietà nel parent FR.
2. **Cause neutrality:** l'identità del SecurityRequirement non dipende da una specifica causa adversarial o non-adversarial; attacco, errore o guasto appartengono al reasoning/analysis downstream.

3. **Single governing security property:** proprietà indipendentemente evolvibili o assessable producono SecurityRequirement distinti.
4. **Functional boundary:** ordinary functional correctness resta nell'FR anche quando è security-relevant.
5. **Attack boundary:** una descrizione di attacco non è un SecurityRequirement.
6. **Realization boundary:** control, protocollo, algoritmo o deployment mechanism non sono automaticamente SecurityRequirement semantics.

Il corpus telecamera valida la forma con SecurityRequirement locali di Confidentiality, Integrity e Authorized Provenance sul comportamento FR-3.4 Deliver RecognitionCapture; le cause e le realizzazioni possono mutare senza cambiare automaticamente l'identità normativa del requisito.

4.11 Regole di authoring end-to-end

La sequenza finale del layer documentale è:

1. **Frame the problem.** Definire problema, boundary e out-of-scope rimuovendo solution vocabulary.
2. **Decompose into MR.** Identificare responsabilità macro stabili, controllando overlap, dipendenze e resilienza.
3. **Review the Macro Project Map.** Segnalare MR isolati e applicare l'Isolated-MR review: autonomia valida, edge mancante o concern-bucket?
4. **Expose Decisions.** Esplicitare commitment su responsibility boundary, policy, strategia, architettura o contratto significativo.
5. **Write operational FRs.** Tradurre ogni Decision in Requirement operativi osservabili e indipendentemente valutabili.
6. **Add structured references.** Supportare la prosa normativa con riferimenti riusabili senza creare una seconda autorità semantica.
7. **Review cross-branch consumption.** Rendere visibili capability consumate senza trasferire ownership.
8. **Specialize downward.** Aggiungere SpecializedRequirement concern-specific senza riscrivere la funzione di base.
9. **Classify security specializations.** Quando lo SR preserva una proprietà di sicurezza, modellarlo come SecurityRequirement, identificare una sola

`protectedSecurityProperty` e rendere esplicito il failure mode nelle normative clause.

Tabella 4.2: Domande di authoring per i livelli documentali.

Livello	Domanda
Problem framing	Quale problema o classe di problemi affrontiamo se rimuoviamo le soluzioni correnti?
MR	Quale responsabilità macro stabile e autonomamente significativa governiamo, quale valore produce e chi coinvolge?
MR graph review	Se l'MR è isolato, resta una responsabilità macro autonoma oppure raccoglie soprattutto proprietà/constraint di altri rami?
Decision	Quale commitment significativo restringe questa responsabilità e quali conseguenze accettiamo?
FR	Dato quel commitment, quale comportamento operativo deve accadere e con quale risultato/failure behavior?
Specialized Requirement	Quale obbligazione concern-specific aggiuntiva deve valere insieme alla funzione senza sostituirla?
Security Requirement	Quale singola proprietà di sicurezza deve essere preservata e quale failure mode nelle clause ne renderebbe osservabile la violazione nel parent FR?

4.12 Ruolo del tool nell'authoring

La regolarità della gerarchia consente assistenza prevedibile, ma il tool segue il metamodello e non lo determina. Può:

- mostrare la gerarchia e impedire parentage non ammessi;
- suggerire riferimenti esistenti evitando duplicazioni;
- filtrare Predicate compatibili;
- segnalare incoerenze tra prosa e SPO;
- costruire Macro Project Map e **segnalare MR a grado zero per review semantica**, senza invalidarli automaticamente;
- avviare proposal workflow espliciti quando manca una voce nel registro.

Non deve trasformare automaticamente nomi estratti dalla prosa in semantica canonica, né usare similarity ranking per decidere equivalenza, parentage o ownership.

In prospettiva L3/L4, l'assistenza può anche suggerire il riuso di nomi, predicati o voci tassonomiche già governate e segnalare probabili sinonimi/parafrasi. La suggestion non canonizza il termine: identity, ownership e accettazione restano decisioni governate. La formalizzazione del vocabolario BAE e delle proiezioni analitiche appartiene alla Base Analysis e non viene anticipata qui.

4.13 Validazione mediante probe iterativi

La costruzione del modello usa esempi, controesempi, mutation test e regressioni. I primi facial-access probe e il primo holdout order/inventory non sono stati trattati come prova definitiva perché contenevano Decision implicite o responsabilità semplificate. Il corpus warehouse R3 ha sostenuto il parent Decision obbligatorio rendendo esplicito il responsibility boundary.

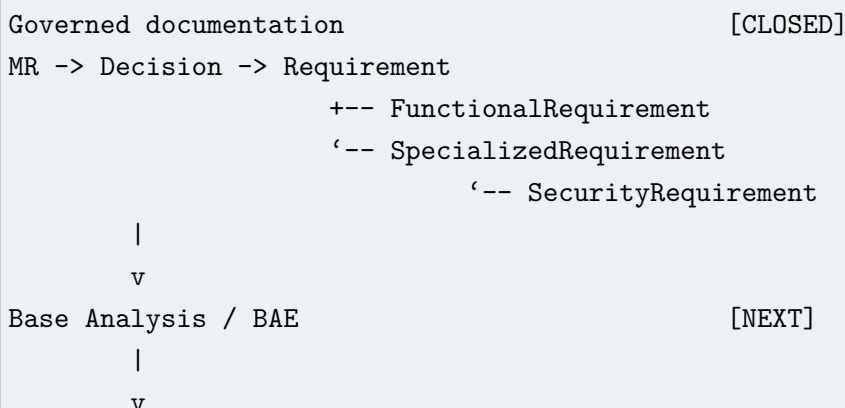
La regressione MR-0004 ha mostrato che un concern trasversale può essere stato promosso troppo presto a MacroRequirement. S1 ha poi chiuso SpecializedRequirement come strengthening locale; S1.5 ha rimosso il wrapper NormativeObligation chiudendo Requirement come unità normativa coerente; S2 ha tipizzato i tre SR telecamera come SecurityRequirement e li ha sottoposti a cause/realization/architecture mutation.

Lezione metodologica

La documentazione non deve essere perfetta prima dell'analisi. Deve essere plausibile, governata e sufficientemente strutturata da consentire ai probe successivi di scoprire errori di classificazione, gap e nuovi obblighi. Le correzioni devono modificare il minimo owning layer, essere tracciabili e regredire i corpus già accettati.

4.14 Confine verso Base Analysis

Con S2 il governed documentation metamodel è chiuso fino a SecurityRequirement. Questa closure non equivale alla closure dell'intero DDTA: il prossimo owning layer è la rappresentazione analizzabile del sistema/progetto.



```

AnalysisRecord / Finding                                [OPEN]
  |
  v
method-neutral overlay/plugin contract                  [OPEN]
  |
  v
STRIDE / STRIDE-AI                                    [DEFERRED]
  |
  v
accepted analytical feedback -> governed change
  |
  v
Base Analysis refresh -> re-analysis

```

Elementi intenzionalmente non chiusi dal Capitolo 4

Restano fuori dal layer documentale: rappresentazione della shared normative source; contratto completo lifecycle/history/change-event; esatta rappresentazione L2 delle normative clause; tassonomia SecurityProperty; eventuale identità strutturale di SecurityFailureMode; Base Analysis/BAE; Finding/AnalysisRecord; overlay/plugin; STRIDE/STRIDE-AI; Risk, Control ed evidence. Il fatto che questi elementi siano aperti non rende provvisorio il documentation metamodel: ciascuno deve essere formalizzato nel proprio owning layer e può riaprire il Capitolo 4 solo tramite un controesempio concreto.

4.15 Condizioni di riapertura

Il Capitolo 4 è CLOSED / FINAL per lo scope corrente. MR, Decision, Requirement, FR, SR o SecurityRequirement possono essere riaperti soltanto se una fase successiva mostra un controesempio concreto e ricorrente non rappresentabile senza perdita o distorsione. In particolare:

1. Base Analysis richiede semantica di progetto che il modello di authoring impedisce attivamente di esprimere;
2. una obbligazione method-neutral non può essere posseduta correttamente con i parent/cardinality chiusi;
3. un concreto subtype di Requirement non può usare normativeClause [1..*] e coherent-unit senza perdita;
4. un SecurityRequirement valido richiede un contratto method-independent incompatibile con S2;

5. il layer Decision costante o la composizione cross-branch producono un errore semantico ricorrente, non un semplice costo di authoring;
6. una regola qui chiusa forza duplicazione o perdita di authoritative project knowledge.

Non costituiscono da soli condizioni di riapertura: aggiungere un BAE o una relazione analitica, introdurre una nuova vista grafica, aggiungere payload privato a un plugin, suggerire un sinonimo tramite tool/LLM, formalizzare Attack/Finding/Risk/Control o scegliere una nuova realizzazione tecnica.

Ogni riapertura deve nominare il controesempio, modificare il minimo owning layer e regressare i corpus precedenti.

4.16 Conclusioni

La baseline DDTA separa domande che nella documentazione ordinaria tendono a mescolarsi. L'MR stabilisce quale responsabilità macro appartiene al progetto; la Decision stabilisce quale commitment la restringe; il Requirement fornisce l'astrazione normativa comune; l'FR stabilisce quale comportamento operativo deve conseguire; lo SpecializedRequirement rafforza localmente la funzione; il SecurityRequirement rende tale strengthening specificamente security-oriented tramite una singola proprietà di sicurezza governata e un failure mode esplicito nelle clause.

La regressione MR-0004, la closure S1, la normalizzazione S1.5 e il corpus S2 mostrano che concern trasversali non richiedono MacroRequirement dedicati e che la semantica di sicurezza non deve essere confusa con attacco, finding o control. Il layer documentale resta quindi stabile anche quando cambiano cause, realizzazioni o tecniche di analisi.

Il metodo rimane deliberatamente pratico: non richiede una documentazione perfetta o completa prima dell'analisi. Richiede documentazione governata sufficiente a rendere esplicite responsabilità, commitment e obbligazioni conosciute. Il prossimo problema scientifico non è riscrivere questi documenti, ma costruire da essi una Base Analysis methodology-neutral con BAE, relazioni, provenance e proiezioni revisionabili.

Traceability della closure finale

La finalizzazione è eseguita sulla baseline repository `ec6c0107e0d5c0460d2afcbe12dae6f40bc5e6c5`. Mantiene le closure precedenti e consolida i seguenti artefatti principali:

- `03-functional-requirement/04-closure/DDTA_DOCUMENT_METAMODEL_THROUGH_FR_CLOSURE_R2.md`;
- `04-specialized-requirement/01-metamodel/DDTA_SPECIALIZED_REQUIREMENT_S1_R2.tex/.pdf`;
- `04-specialized-requirement/03-example-facial-access/DDTA_FACIAL_ACCESS_CAMERA_S1_STUDY_CORPUS_R2.tex/.pdf`;
- `04-specialized-requirement/04-s1-5-working/DDTA_S1_5_REQUIREMENT_ABSTRACTION_PROVENANCE_WORKING.tex/.pdf`;
- `05-security-requirement/01-metamodel/DDTA_SECURITY_REQUIREMENT_S2_R1.tex/.pdf`.

Stato finale del blocco documentale:

MR	CLOSED
Decision	CLOSED
Requirement	CLOSED
FunctionalRequirement	CLOSED
SpecializedRequirement	CLOSED
SecurityRequirement	CLOSED
Base Analysis / BAE	NEXT